

Security Test Cases

TEST SPECIFICATION

1. PURPOSE

The purpose of these security tests is to verify that authentication, role-based access control (RBAC), and organizational scope are correctly enforced by the backend API.

The tests verify that each user can access only the resources and actions permitted by their role and organizational scope.

2. AUTHENTICATION TESTS

ID	TEST CASE	EXPECTED RESULT
AUTH-01	Access a protected API without authentication	401 Unauthorized
AUTH-02	Access a protected API with an invalid token	401 Unauthorized
AUTH-03	Access a protected API with an expired token	401 Unauthorized
AUTH-04	Login with valid credentials	Authentication succeeds
AUTH-05	Login with invalid credentials	Authentication fails
AUTH-06	Use a revoked refresh token	Request is rejected

3. ASSET ADMINISTRATOR TESTS

ID	TEST CASE	EXPECTED RESULT
ADM-01	Create an asset	Allow
ADM-02	Update asset information	Allow
ADM-03	Import assets	Allow
ADM-04	Transfer an asset	Allow
ADM-05	Retire an asset	Allow
ADM-06	Read procurement references	Allow
ADM-07	Modify invoice/financial data	Deny unless explicitly granted
ADM-08	Access asset outside assigned organizational scope	Deny

4. PROCUREMENT / FINANCE TESTS

ID	TEST CASE	EXPECTED RESULT
PRO-01	Read asset information	Allow
PRO-02	Create/update supplier information	Allow
PRO-03	Create/update purchase order	Allow
PRO-04	Create/update invoice	Allow
PRO-05	Read warranty information	Allow
PRO-06	Read cost information	Allow
PRO-07	Modify general asset information	Deny
PRO-08	Transfer an asset	Deny
PRO-09	Retire an asset	Deny
PRO-10	Access procurement data outside assigned scope	Deny

5. CUSTODIAN / DEPARTMENT MANAGER TESTS

ID	TEST CASE	EXPECTED RESULT
CUS-01	Read assets within assigned department	Allow
CUS-02	Read asset outside assigned department	Deny
CUS-03	Confirm asset assignment	Allow
CUS-04	Report/update asset condition	Allow
CUS-05	Read maintenance status	Allow
CUS-06	Read invoice or receipt	Deny
CUS-07	Read purchase cost	Deny
CUS-08	Modify supplier or purchase order	Deny
CUS-09	Retire an asset	Deny
CUS-10	Access another college's assets by changing resource ID	Deny

6. MAINTENANCE TECHNICIAN TESTS

ID	TEST CASE	EXPECTED RESULT
TECH-01	Read assigned work orders	Allow
TECH-02	Update work order	Allow
TECH-03	Complete work order	Allow
TECH-04	Record service information	Allow
TECH-05	Record parts and downtime	Allow
TECH-06	Read required asset information	Allow
TECH-07	Read invoice/financial information	Deny
TECH-08	Modify general asset information	Deny
TECH-09	Transfer an asset	Deny
TECH-10	Retire an asset	Deny

7. AUDITOR TESTS

ID	TEST CASE	EXPECTED RESULT
AUD-01	Read asset inventory	Allow
AUD-02	Read financial references	Allow within assigned scope
AUD-03	Read custody and transfer history	Allow
AUD-04	Read maintenance history	Allow
AUD-05	Read audit logs	Allow
AUD-06	Create an asset	Deny
AUD-07	Modify an asset	Deny
AUD-08	Transfer an asset	Deny
AUD-09	Retire an asset	Deny
AUD-10	Modify a work order	Deny

8. ORGANIZATIONAL SCOPE TESTS

ID	TEST CASE	EXPECTED RESULT
SCOPE-01	User accesses a resource inside assigned scope	Allow
SCOPE-02	User accesses a resource outside assigned scope	Deny
SCOPE-03	User accesses a child organization under assigned scope	Allow
SCOPE-04	User accesses a sibling organization	Deny
SCOPE-05	User has multiple scopes and accesses resources in each scope	Allow
SCOPE-06	User attempts to modify their own organizational scope	Deny
SCOPE-07	User changes the resource ID to access another organization's asset	Deny
SCOPE-08	User attempts to access financial data outside their assigned scope	Deny

9. PRIVILEGE ESCALATION TESTS

ID	TEST CASE	EXPECTED RESULT
PRIV-01	Technician attempts an administrator action	Deny
PRIV-02	Custodian attempts a procurement action	Deny
PRIV-03	Auditor attempts to modify any resource	Deny
PRIV-04	Procurement user attempts asset retirement	Deny
PRIV-05	User attempts to modify their own role	Deny
PRIV-06	User attempts to assign themselves a higher role	Deny
PRIV-07	User attempts to access an endpoint belonging to another role	Deny

10. RESOURCE-LEVEL AUTHORIZATION TESTS

The backend must verify authorization for the specific resource, not only the user's role.

ID	TEST CASE	EXPECTED RESULT
RES-01	Authorized user accesses an allowed asset	Allow
RES-02	Authorized role accesses an asset outside its scope	Deny
RES-03	User changes asset ID to another asset outside scope	Deny
RES-04	User changes invoice ID to another invoice	Access controlled by permission and scope
RES-05	User accesses a retired asset	Read-only according to policy
RES-06	User attempts to modify a retired asset	Deny

11. AUDIT AND SECURITY LOGGING TESTS

ID	TEST CASE	EXPECTED RESULT
AUDIT-01	Asset transfer is performed	Audit event is created
AUDIT-02	Asset retirement is performed	Audit event is created
AUDIT-03	Permission/role change occurs	Audit event is created
AUDIT-04	Unauthorized access attempt occurs	Security event is logged
AUDIT-05	User attempts to modify audit history	Deny
AUDIT-06	Sensitive credentials/tokens are written to logs	Must not occur

12. SECURITY ACCEPTANCE CRITERIA

The RBAC implementation is considered acceptable when:

- Unauthenticated users cannot access protected resources.
- Each role can perform only its authorized actions.
- Users cannot access resources outside their organizational scope.
- Users cannot escalate their own privileges.
- Financial data is separated from general asset access.
- Auditors remain read-only.
- Custody, transfer, retirement, and permission events are auditable.
- Authorization is enforced by the backend API and not only by the frontend.
- Resource-level and organization-level authorization cannot be bypassed by changing IDs or request parameters.

13. FILE AND ATTACHMENT AUTHORIZATION TESTS

These tests verify that file and attachment access is correctly restricted according to AST-SEC-REQ-24 through AST-SEC-REQ-27.

ID	TEST CASE	EXPECTED RESULT
FILE-01	Upload a file without authentication	401 Unauthorized
FILE-02	Download a file attachment outside the user's organizational scope	403 Forbidden
FILE-03	Upload a file with a disallowed file type (e.g. .exe, .sh)	400 Bad Request
FILE-04	Access a file directly via its storage URL without a valid download token	Deny (403 or redirect to auth)
FILE-05	Role without documents:read permission attempts to download an attachment	403 Forbidden

15. RATE LIMITING AND BRUTE-FORCE TESTS

These tests verify that authentication endpoints enforce rate limiting and temporary lockout controls as required by AST-SEC-REQ-41.

ID	TEST CASE	EXPECTED RESULT
RL-01	Submit more than the allowed number of failed login attempts from one IP within the lockout window	Account or IP is temporarily locked; further attempts are rejected with 429 Too Many Requests or equivalent
RL-02	Submit repeated password-reset requests for the same account in quick succession	Rate limit applies; excess requests are rejected or silently dropped
RL-03	Submit a valid login after a lockout period expires	Authentication succeeds normally
RL-04	Send a high volume of requests to a protected API endpoint from one token	Rate limit applies; 429 returned after threshold is exceeded

16. MALWARE SCAN AND FILE QUARANTINE TESTS

These tests verify that uploaded attachments are malware-scanned before download or business use and that suspicious files are quarantined, as required by AST-SEC-REQ-45.

ID	TEST CASE	EXPECTED RESULT
MAL-01	Upload an attachment containing a known malware signature (e.g. EICAR test file)	Upload is accepted for scanning; file is quarantined and not made available for download or business use
MAL-02	Attempt to download an attachment that is in quarantine status	403 Forbidden or equivalent; file is not served
MAL-03	Upload a clean file of an allowed type and size	Upload succeeds; file passes scan and becomes available for authorized download
MAL-04	Upload a file that exceeds the maximum allowed size	400 Bad Request – upload rejected before scan
MAL-05	Upload a file with a disallowed extension disguised with an allowed extension (e.g. malware.exe renamed to malware.pdf)	Upload is rejected by type/content validation or quarantined after scan

17. FILE PATH AND STORAGE KEY INJECTION TESTS

These tests verify that file names and storage keys are validated and that file paths or access decisions are not derived from user-controlled input, as required by AST-SEC-REQ-46.

ID	TEST CASE	EXPECTED RESULT
FPATH-01	Submit a download request with a storage key containing path-traversal sequences (e.g. ../../etc/passwd)	Request is rejected; traversal attempt is not executed
FPATH-02	Submit a storage key derived from a guessed or externally constructed URL without a valid download token	403 Forbidden or redirect to authentication
FPATH-03	Submit a file name containing null bytes or special characters in an upload request	Upload is rejected or the file name is sanitized; no path manipulation occurs
FPATH-04	Attempt to access a private storage object directly via its raw storage URL without authorization	403 Forbidden or equivalent; object is not served

18. FLUTTER CLIENT-SIDE SECURITY TESTS

These tests verify that the Flutter mobile client stores and handles authentication tokens securely as required by AST-SEC-REQ-04, AST-SEC-REQ-31, and AST-SEC-REQ-54. These tests are client-side and complement the backend API tests above.

ID	TEST CASE	EXPECTED RESULT
FLUTTER-01	Access token is stored in flutter_secure_storage after login	Token found in flutter_secure_storage only; SharedPreferences contains no token
FLUTTER-02	SharedPreferences does not contain access token or refresh token at any point	No tokens found in SharedPreferences
FLUTTER-03	Logout clears access token and refresh token from flutter_secure_storage	flutter_secure_storage is empty after logout
FLUTTER-04	Expired access token causes automatic silent refresh using refresh token	New access token is issued; user session continues without interruption
FLUTTER-05	Both access token and refresh token are expired — user attempts an API call	User is redirected to the login screen; no token appears in error output
FLUTTER-06	Revoked refresh token is used to attempt token renewal	401 TOKEN_REVOKED is returned; user is logged out
FLUTTER-07	Application crash report or debug log does not contain token values	No access token, refresh token, or password appears in crash reports or application logs
FLUTTER-08	Session revocation on the backend (e.g. password change) causes subsequent API calls to fail	401 TOKEN_REVOKED returned; Flutter clears stored tokens and redirects to login

19. SCOPE GRANT EXPIRY AND INCLUDE_DESCENDANTS TESTS

These tests verify the include_descendants flag behaviour and expired grant handling defined in the Organizational Scope model (AST-SEC-REQ-10 to AST-SEC-REQ-13).

ID	TEST CASE	EXPECTED RESULT
SCOPE-09	User has a scope grant with include_descendants = FALSE; user requests an asset in a child location of the granted location	Deny — child location is not included without include_descendants = TRUE
SCOPE-10	Scope grant has an expires_at timestamp in the past; user requests a resource under that grant	Deny — expired grant is treated as revoked at request time
SCOPE-11	User has two scope grants, one active and one expired; user requests resources under each	Allow for the active grant only; deny for the expired grant

20. SESSION LIFECYCLE AND SELF-APPROVAL PREVENTION TESTS

These tests verify session revocation behaviour (AST-SEC-REQ-42) and separation-of-duties controls that prevent a requester from approving their own sensitive workflows (AST-SEC-REQ-44).

ID	TEST CASE	EXPECTED RESULT
SESSION-01	User logs out; stored refresh token is used to attempt a new access token	Token is revoked at logout; refresh attempt is rejected with 401 TOKEN_REVOKED
SESSION-02	User changes password; existing refresh token is used to request a new access token	All existing sessions are revoked; refresh token is rejected
SESSION-03	Refresh token is rotated on each use — old refresh token is replayed after a new one has been issued	Old refresh token is rejected; replay attempt does not issue a new access token
APPROVAL-01	User submits an asset transfer request and then attempts	Deny — self-approval is rejected; a